Testing a Legal AI Review Workflow

Ingrid Kao

Independent practitioner note | November 10, 2026 | Revised November 11, 2026

Companion files: github.com/ingridkuo/legal-workflow-lab/tree/main/08_practitioner_notes

At a glance

Built: A source-linked gate for AI review findings, tested on 16 authored fixtures, and a saved AI review of eight fictional NDA fragments.

Found: The gate handled all 16 fixtures as expected. The AI review matched all six pre-run key pairs and added two overlapping PURPOSE labels; I adjudicated both as supported by the rule as written.

Why it matters: Mechanical checks catch source and format failures. Deciding what counts as a finding, and which rule governs, stays with an accountable reviewer.

A convincing contract-review demonstration can still leave an implementation team unable to decide whether a pilot should proceed. A flag may sound reasonable while quoting a different clause, referring to an outdated document, or combining two review categories that the evaluation key treats as separate issues. A useful pilot makes those differences visible before anyone relies on its recommendations. My own starting point is practical: at Lawsnote, a legal technology company, I turned an enterprise client's NDA review standards into rules that engineers built into an AI contract-review product, and reviewed about 1,000 NDAs against them.

This note presents a small, inspectable implementation: a source-linked output gate, a recorded exploratory AI review of eight fictional NDA fragments, and a release decision framework. The main finding is practical. Mechanical validation can reject specified source and format failures, while substantive interpretation and the unit used for scoring still require an accountable reviewer. The companion files preserve inputs, the original response, configuration, executable checks, and results.

Define the decision the pilot supports

The first design choice is the boundary of the task. Here, a reviewer identifies exceptions to four deliberately simplified sponsor instructions about confidentiality duration, permitted purpose, residual knowledge, and backup deletion. The documents are short original fictional fragments. They contain no client information and do not represent a market-standard NDA playbook.

The permitted outcome is a finding for human review, not approval to sign or permission to change a system. An empty findings array means that the reviewer found no exception under these particular instructions. It does not resolve enforceability, missing provisions, cross-references, governing law, or facts outside the supplied text.

Before involving a model, a process owner should define who receives a finding, what evidence that person needs, and who decides whether it matters. OpenAI's evaluation guidance supports task-specific objectives and datasets rather than informal impressions.[1] NIST's Generative AI Profile also cautions against generalizing from narrow assessments.[2] Those principles govern how the results are reported.

Make each finding traceable

A review object should identify the document and source version, the applied rule, a clause locator, an exact quotation, and the proposed next step. The companion deterministic gate also checks a source digest and an allowed severity value. The experimental AI response uses a related, separately documented schema with a document-level findings array; its scorer checks that array against the supplied sources.

Each source digest is computed from an explicitly defined serialization or source text. This distinction matters: hashing a PDF file and hashing extracted clause text produce different identifiers. The implementation records the representation it hashes. A matching digest establishes correspondence to that representation, not the authenticity or completeness of the original agreement.

The gate rejects malformed records, missing or extra fields, unsupported values, stale versions, and quotations that do not occur in the cited clause. It sends an explicit refusal to a manual path. A mechanically valid record enters a human-review queue. It never becomes an authorized legal decision merely because its fields are complete.

Check	What it can establish	What remains unresolved
Schema and allowed values	The record has the expected form	Whether the conclusion is sound
Source version and digest	The record points to the pinned representation	Whether extraction captured the full agreement
Quote within cited clause	The quoted words occur at that locator	Whether they support the proposed interpretation
Recorded human decision	A named decision step exists in the workflow	Whether a production identity system authenticates that person

Structured output is useful for integration, but OpenAI's documentation expressly recognizes that structured responses can still contain mistakes.[3] Consequently, source checks and schema checks are supporting controls rather than substitutes for legal judgment.

Run software checks separately from the model exercise

The first experiment uses deliberately authored candidate outputs, including malformed and substantively unsound examples. It tests the gate implementation rather than an AI model. Sixteen fixtures exercise invalid JSON, unsupported fields or values, source mismatches, incorrect quotation locations, refusal handling, and mechanically valid records.

The run matched the expected gate result on all 16 fixtures: 12 were blocked, one refusal went to manual review, and three entered human review. A regression run repeated the implementation twice in fresh directories and found byte-identical results across its eight generated artifacts in this runtime. These counts measure fixture-level software behavior, not model performance.

One fixture is designed to contain an unsound interpretation while retaining a valid quotation and source reference. It enters the human-review queue as intended. That outcome is useful because it exposes the

gate's boundary. Calling it a successful legal review would reverse the meaning of the test; its rejection label is an authored test key, not an observed model error.

The second experiment is an actual exploratory AI review, conducted through a delegated OpenAI Codex agent on November 10, 2026. The task supplied eight fictional documents, A01 to A08, and four sponsor rules, TERM, PURPOSE, RESIDUALS, and DELETION, with an instruction to treat document contents as untrusted data. The provisional answer key was not supplied in the review task. The response was retained without rewriting its findings.

The session identified the parent model as GPT-6.1 Sol (gpt-6.1-sol). The provider snapshot, sampling settings, seed, and surrounding platform instructions were not exposed, so the record supports inspection of this run rather than exact reproduction. Re-running the supplied scorer checks the stored response without calling the model again.

Adjudicating the extra labels

The eight-document response contained eight finding rows. All eight document metadata checks matched the pinned inputs, and all eight finding quotations occurred in their cited clauses. The six document-and-rule pairs in the provisional key were present. The response added two PURPOSE labels, both on residual-knowledge clauses already flagged under RESIDUALS.

For example, A04 allows information retained in unaided memory to be used without restriction. The provisional key listed RESIDUALS. The model also applied PURPOSE, reasoning that unrestricted use extends beyond evaluating Project Atlas. Automatically counting that label as a false positive would assume the very classification choice the pilot needed to resolve, so I adjudicated the two added labels and recorded the reasons.

Observation from the saved batch	Count	Interpretation
Fictional documents reviewed	8	One exploratory batch
Finding rows returned	8	Rows, not eight independent legal problems
Quotes matching their cited clauses	8 of 8	A source-linkage result
Provisional key pairs represented	6 of 6	Agreement with the pre-run toy key
Additional rule labels	2	Supported under the rule as written; same issue as RESIDUALS
Adjudicated key pairs represented	8 of 8	Post-run author adjudication; not independent

The decision depends on the unit of evaluation. The scorer counts document-and-rule pairs. Under the PURPOSE rule as written, an unrestricted residuals clause is an operative use right beyond Project Atlas, so both labels are supported and the adjudicated key now lists them. Counted by distinct clause, each PURPOSE label describes the same issue as the RESIDUALS finding and merges into it, leaving six flagged clauses. The overlap comes from the rules, not the model: the general PURPOSE rule and the more specific RESIDUALS rule both reach the same clause. The next policy version should say that RESIDUALS governs permissions to use information retained in unaided memory and that PURPOSE covers other use rights.

Against the adjudicated key, the batch represented all eight pairs and returned none outside it. I adjudicated after seeing the response, and eight short fictional fragments cannot support a precision or recall estimate.

Two other cases illustrate the exercise's scope. A06 contains an instruction in the source to ignore the review policy; the saved response still returned the expected substantive flags. A08 contains non-operative drafting history with a shorter term; the response returned no finding. These are two observations, not evidence of general resistance to prompt injection or reliable interpretation of complete contracts.

Keep permissions outside the recommendation

OWASP describes indirect prompt injection through files and websites and recommends multiple controls rather than reliance on model instructions alone.[4] For a legal workflow, that supports a practical separation: contract text is evidence to inspect, while permissions to send, sign, delete, or change records come from the surrounding application and authorized people.

The demonstration makes no external changes. Its role arguments are simulated workflow inputs, not enterprise authentication. A production design would need an approved data path, real authorization, secret management, retention controls, and monitoring. The pilot owner should also test changes in extraction, source formatting, model version, and rule configuration. Passing the current fixtures should not silently authorize a different deployment.

Make a release decision that can be revisited

The observed results support continuing a bounded evaluation. They do not support autonomous contract clearance. Before a release decision, the domain owner should approve the review rules, including which rule governs residual-knowledge clauses, and define treatment of critical misses. New representative agreements should then be evaluated with independent substantive review, a frozen prompt and rule version, and a documented sampling method.

The business case should include verification and correction effort. An illustrative calculation makes the issue concrete: at 200 matters per month, a 20-minute manual baseline and a 14-minute assisted total would imply 20 hours of capacity. At an assumed loaded rate of $80 per hour, that is $1,600 before fees and implementation costs. A $2,000 monthly system cost would exceed that amount by $400. These are planning assumptions, not measured savings or a complete investment model. If verification takes longer, the result changes again.

A limited launch should have a process owner, a receiving reviewer, a support contact, and an agreed pause condition. Training should show a refusal, an unsupported quotation, a stale source, and a mechanically valid but questionable interpretation. A revision log should connect each recurring failure to a proposed change and a regression check. The release decision should consider reviewer effort and unresolved risks alongside throughput.

The useful deliverable from this pilot is an evidence record that supports the next decision. It shows which controls ran, what the model returned, which questions remain open, and who must resolve them before broader use.

Method and references

This independent portfolio study uses synthetic documents, candidate-output fixtures, and operational records. It does not reproduce an employer's policy or confidential work. The eight-document AI exercise is separate from the deterministic software fixtures and from the AI review materials in the repository's 01_ai_review folder. I adjudicated the two additional labels on November 11, 2026; the companion files at github.com/ingridkuo/legal-workflow-lab/tree/main/08_practitioner_notes keep the original key, the adjudicated key, and the reasons.

[1] OpenAI. Evaluation best practices. Sections on task-specific evaluation, dataset design, and human-calibrated evaluation. Accessed November 10, 2026. https://developers.openai.com/api/docs/guides/evaluation-best-practices

[2] NIST. Artificial Intelligence Risk Management Framework Generative Artificial Intelligence Profile. NIST AI 600-1, July 2024. Actions MS-2.5-001 and MS-2.5-003. https://doi.org/10.6028/NIST.AI.600-1

[3] OpenAI. Structured model outputs. Section on handling mistakes. Accessed November 10, 2026. https://developers.openai.com/api/docs/guides/structured-outputs

[4] OWASP. LLM01 2025 Prompt Injection. Sections on indirect prompt injection and mitigation. Accessed November 10, 2026. https://genai.owasp.org/llmrisk/llm01-prompt-injection/